Scattered Spider Investigation Process

MFA Fatigue & BEC Investigation (Audit-Ready with Full Coverage)

📌 Objective

Conduct a full investigation using Microsoft Sentinel logs to identify attacker activity, persistence, impact, and attribution. Each question includes objective, KQL query, thought process, screenshot placeholder, answer, and MITRE mapping where applicable.

Q1 – Workspace

Objective: Identify Sentinel workspace **Thought Process:** Verified workspace name in portal UI 📸 *Figure 1: Sentinel workspace view* **Answer:** law-cyber-range

---

Q2 – Compromised Account

Objective: Identify compromised user

```
SigninLogs | where Identity contains "Mark Smith" | project TimeGenerated, ResultSignature, ResultDescription, Identity, Location, AlternateSignInName, AppDisplayName, UserPrincipalName, Type | sort by TimeGenerated asc
```

Thought Process: Filter by name to find login identity

Answer: m.smith@lognpacific.org

MITRE: T1078

TimeGenerated [UTC]	2026-02-25T21:44:11.8042067Z
ResultSignature	SUCCESS
Identity	Mark Smith
Location	US
AlternateSignInName	m.smith@lognpacific.org
AppDisplayName	OfficeHome
UserPrincipalName	m.smith@lognpacific.org
Type	SigninLogs

Q3 – Attacker IP

Objective: Identify suspicious IP

```
SigninLogs | where Identity contains "Mark Smith" | project
TimeGenerated, ResultSignature, ResultDescription, Identity, Location,
AlternateSignInName, AppDisplayName, UserPrincipalName, Type,
IPAddress | sort by TimeGenerated asc
```

Thought Process: Identify abnormal IP activity.

Answer: 205.147.16.190

TimeGenerated [UTC]	2026-02-25T21:54:24.731913Z
ResultSignature	FAILURE
ResultDescription	Strong Authentication is required.
Identity	Mark Smith
Location	NL
AlternateSignInName	m.smith@lognpacific.org
AppDisplayName	One Outlook Web
UserPrincipalName	m.smith@lognpacific.org
Type	SigninLogs
IPAddress	205.147.16.190

Q4 – Country

Objective: Identify attacker location

```
SigninLogs | where Identity contains "Mark Smith" | project
TimeGenerated, ResultSignature, ResultDescription, Identity, Location,
AlternateSignInName, AppDisplayName, UserPrincipalName, Type,
IPAddress | sort by TimeGenerated asc
```

Thought Process: Use geolocation field.

Answer: NL

TimeGenerated [UTC]	2026-02-25T21:54:24.731913Z
ResultSignature	FAILURE
ResultDescription	Strong Authentication is required.
Identity	Mark Smith
Location	NL
AlternateSignInName	m.smith@lognpacific.org
AppDisplayName	One Outlook Web
UserPrincipalName	m.smith@lognpacific.org
Type	SigninLogs
IPAddress	205.147.16.190

Q5 – MFA Denial Error Code

Objective: Identify MFA error code

```
SigninLogs | where Identity contains "Mark Smith" | project
TimeGenerated, ResultSignature, ResultDescription, Identity, Location,
AlternateSignInName, AppDisplayName, UserPrincipalName, Type,
IPAddress, Status | sort by TimeGenerated asc
```

Thought Process: Extract Error Code.

Answer: 50074

2/25/2026, 9:54:24.731 PM	FAILURE	Strong Authentication is required.
TimeGenerated [UTC]	2026-02-25T21:54:24.731913Z	
ResultSignature	FAILURE	
ResultDescription	Strong Authentication is required.	
Identity	Mark Smith	
Location	NL	
AlternateSignInName	m.smith@lognpacific.org	
AppDisplayName	One Outlook Web	
UserPrincipalName	m.smith@lognpacific.org	
Type	SigninLogs	
IPAddress	205.147.16.190	
Status	{"errorCode":50074,"additionalDetails":"Authentication in progress","failure	
additionalDetails	Authentication in progress	
errorCode	50074	
failureReason	Strong Authentication is required.	

Q6 – MFA Fatigue Intensity Attempts

Objective: Count failures before success

```
SigninLogs | where Identity contains "Mark Smith" | project
TimeGenerated, ResultSignature, ResultDescription, Identity, Location,
AlternateSignInName, AppDisplayName, UserPrincipalName, Type,
IPAddress, Status | sort by TimeGenerated asc
```

Thought Process: Count failed attempts sequence.

Answer: 3

2/25/2026, 9:44:18.537 PM	SUCCESS	172.175.65.103
2/25/2026, 9:44:23.800 PM	FAILURE	172.175.65.103
2/25/2026, 9:54:24.731 PM	FAILURE	205.147.16.190
2/25/2026, 9:54:55.422 PM	FAILURE	205.147.16.190
2/25/2026, 9:55:15.212 PM	FAILURE	205.147.16.190
2/25/2026, 9:59:52.798 PM	SUCCESS	205.147.16.190
2/25/2026, 10:00:24.901 PM	SUCCESS	205.147.16.190
2/25/2026, 10:01:11.677 PM	SUCCESS	205.147.16.190

Q7 – Application Accessed

Objective: *Identify which application the attacker accessed after MFA bypass.*

```
SigninLogs | where Identity contains "Mark Smith" | where IPAddress ==
"205.147.16.190" | where ResultType == "0" | project TimeGenerated,
ResultSignature, ResultType, IPAddress, ResultDescription, Identity,
Location, AlternateSignInName, AppDisplayName, UserPrincipalName,
Type, Status | sort by TimeGenerated asc
```

Thought Process: *What App other than Desktop App did the attacker use?*

Answer: One Outlook Web

2/25/2026, 9:59:52.798 PM	SUCCESS	0	205
TimeGenerated [UTC]	2026-02-25T21:59:52.7988431Z		
ResultSignature	SUCCESS		
ResultType	0		
IPAddress	205.147.16.190		
Identity	Mark Smith		
Location	NL		
AppDisplayName	One Outlook Web		
UserPrincipalName	m.smith@lognpacific.org		
Type	SigninLogs		
Status	{"errorCode":0,"additionalDetails":"MFA requirement satisfied by claim in the token"}		

Q8 – Operating System Attacker Used

Objective: *Determine the OS used by the attacker and compare it to the legitimate user baseline.*

```
CloudAppEvents |where IPAddress == "205.147.16.190" | project
TimeGenerated, IPAddress, OSPlatform
```

Thought Process: *Search to see if attacker used different OS.*

Answer: Linux

Browser: *Firefox 147.0*

TimeGenerated [UTC]	2026-02-25T22:00:24.9013779Z
ResultSignature	SUCCESS
ResultType	0
IPAddress	205.147.16.190
Identity	Mark Smith
Location	NL
AppDisplayName	One Outlook Web
UserPrincipalName	m.smith@lognpacific.org
Type	SigninLogs
Status	{"errorCode":0,"additionalDetails":"MFA requirement satisfied by claim in the token"}
DeviceDetail	**{"deviceId":"","operatingSystem":"Linux","browser":"Firefox 147.0"}**
browser	Firefox 147.0
deviceId	
operatingSystem	Linux

Q9 – First Post-Auth Action

Objective: *Find what the attacker did once inside.*

```
CloudAppEvents | where IPAddress == "205.147.16.190" |project
TimeGenerated, ActionType, IPAddress, ObjectName | sort by
TimeGenerated asc
```

Thought Process: `Search for attacker's first intent.`

Answer: MailItemsAccessed

TimeGenerated [UTC]	2026-02-25T21:56:24Z
ActionType	MailItemsAccessed
IPAddress	205.147.16.190
ObjectName	MailItemsAccessed

Q10 – Rule Creation Method

Objective: *Search for any established persistence in the mailbox.*

```
CloudAppEvents | where IPAddress == "205.147.16.190" |project
TimeGenerated, ActionType, IPAddress, ObjectName | sort by
TimeGenerated asc
```

Thought Process: *Search for any rule concerning the mailbox*

Answer: New-InboxRule

TimeGenerated [UTC]	2026-02-25T22:02:33Z
ActionType	New-InboxRule
IPAddress	205.147.16.190
ObjectName	.

Q11 – Forward Rule Name

Objective: *Extract the exact rule name.*

```
CloudAppEvents | where IPAddress == "205.147.16.190" |project
TimeGenerated, ActionType, IPAddress, ObjectName, RawEventData | sort
by TimeGenerated asc
```

Thought Process: *Extract rule name using RawEventData JSON.*

Answer: .

{"Name":"Name","Value":"."},{"N

Q12 – Forward Destination Address

Objective: *Find where the external email address where the messages are being forwarded.*

```
CloudAppEvents | where IPAddress == "205.147.16.190" |project
TimeGenerated, ActionType, IPAddress, ObjectName, RawEventData, | sort
by TimeGenerated asc
```

Thought Process: Extract external email address using RawEventData JSON

Answer: insights@duck.com

},{"Name":"ForwardTo","Value":"insights@duck.com"},

Q13 – Financial Forward Keywords

Objective: *Identify the keywords used the in malicious inbox rule that trigger forwarding.*

```
CloudAppEvents | where IPAddress == "205.147.16.190" |project
TimeGenerated, ActionType, IPAddress, ObjectName, RawEventData | sort
by TimeGenerated asc
```

Thought Process: *Extract financial keywords used in the malicious inbox rule.*

Answer: invoice, payment, wire, transfer

{"Name":"Name","Value":"."},{"Name":"SubjectOrBodyContainsWords","Value":"invoice, payment, wire, transfer"},

---

Q14 – Rule Processing Flag

Objective: *Identify the parameter that ensures that no other rules run after this one.*

```
CloudAppEvents | where IPAddress == "205.147.16.190" |project
TimeGenerated, ActionType, IPAddress, ObjectName, RawEventData | sort
by TimeGenerated asc
```

Thought Process: *Extract parameters from the RawEventsData JSON.*

Answer: StopProcessingRules

Parameters	[{"Name":"AlwaysDeleteOutlookRulesBlob","Value":"False"},{"Name":"Force","Value":"False"},{"Name":"Name","Value":".."},{"Name":"SubjectOrBodyContainsWo...
0	{"Name":"AlwaysDeleteOutlookRulesBlob","Value":"False"}
1	{"Name":"Force","Value":"False"}
2	{"Name":"Name","Value":".."}
3	{"Name":"SubjectOrBodyContainsWords","Value":"suspicious, security, phishing, unusual, compromised, verify"}
4	{"Name":"DeleteMessage","Value":"True"}
5	{"Name":"StopProcessingRules","Value":"True"}

Q15 – Delete Rule Name

Objective: *Find anymore rule creations during the attack window.*

CloudAppEvents | where IPAddress == "205.147.16.190" | where ActionType contains "Rule" | project TimeGenerated, ActionType, IPAddress, ObjectName, RawEventData | sort by TimeGenerated asc

Thought Process: *Query in the CloudAppEvents table for any more creation rules in RawEventData JSON and what is the name of the rule?*

Answer: ..

Parameters	[{"Name":"AlwaysDeleteOutlookRulesBlob","Value":"False"},{"Name":"Force","Value":"False"},{"Nam
> 0	{"Name":"AlwaysDeleteOutlookRulesBlob","Value":"False"}
> 1	{"Name":"Force","Value":"False"}
> 2	{"Name":"Name","Value":".."}
> 3	{"Name":"SubjectOrBodyContainsWords","Value":"suspicious, security, phishing, unusual, compromised, verify"}
> 4	{"Name":"DeleteMessage","Value":"True"}
> 5	{"Name":"StopProcessingRules","Value":"True"}

Q16 – Keyword Deletion Attempt

Objective: *Search for any keywords targeted for deletion.*

```
CloudAppEvents | where IPAddress == "205.147.16.190" | where
ActionType contains "Rule" |project TimeGenerated, ActionType,
IPAddress, ObjectName, RawEventData | sort by TimeGenerated asc
```

Thought Process: *Using CloudAppEvents, query for any keywords targeted for deletion using RawEventsData JSON.*

Answer: suspicious, security, phishing, unusual, compromised, verify

Parameters	[{"Name":"AlwaysDeleteOutlookRulesBlob","Value":"False"},{"Name":"Force","Value":"False"},{"Name"
> 0	{"Name":"AlwaysDeleteOutlookRulesBlob","Value":"False"}
> 1	{"Name":"Force","Value":"False"}
> 2	{"Name":"Name","Value":".."}
> 3	{"Name":"SubjectOrBodyContainsWords","Value":"suspicious, security, phishing, unusual, compromised, verify"}
> 4	{"Name":"DeleteMessage","Value":"True"}
> 5	{"Name":"StopProcessingRules","Value":"True"}

Q17 – BEC Target

Objective: *Figure out who received the fraudulent email.*

```
EmailEvents | where SenderDisplayName contains "Smith" | where
SenderFromAddress contains "m.smith@lognpacific.org" | where
SenderIPv4 == "205.147.16.190" | project TimeGenerated,
SenderDisplayName, SenderFromAddress, DeliveryAction,
DeliveryLocation, RecipientEmailAddress, RecipientDomain
```

Thought Process: *Using EmailEvents query to find who received the fraudulent email.*

Answer: j.reynolds@lognpacific.org

2/25/2026, 10:06:39.000 PM	Mark Smith
TimeGenerated [UTC]	2026-02-25T22:06:39Z
SenderDisplayName	Mark Smith
SenderFromAddress	m.smith@lognpacific.org
DeliveryAction	Delivered
DeliveryLocation	Inbox/folder
RecipientEmailAddress	j.reynolds@lognpacific.org
RecipientDomain	lognpacific.org

Q18 – BEC Subject Line

Objective: *Figure out the "subject" of the fraudulent email.*

```
EmailEvents | where SenderDisplayName contains "Smith" | where
SenderFromAddress contains "m.smith@lognpacific.org" | where
SenderIPv4 == "205.147.16.190" | project TimeGenerated,
SenderDisplayName, SenderFromAddress, DeliveryAction,
DeliveryLocation, RecipientEmailAddress, RecipientDomain, Subject
```

Thought Process: *Search "EmailEvents" table for the "subject" of the fraudulent email from the compromised account.*

Answer: RE: Invoice #INV-2026-0892 - Updated Banking Details

2/25/2026, 10:06:39.000 PM	Mark Smith	m.smith@lognpacif
TimeGenerated [UTC]	2026-02-25T22:06:39Z	
SenderDisplayName	Mark Smith	
SenderFromAddress	m.smith@lognpacific.org	
DeliveryAction	Delivered	
DeliveryLocation	Inbox/folder	
RecipientEmailAddress	j.reynolds@lognpacific.org	
RecipientDomain	lognpacific.org	
Subject	RE: Invoice #INV-2026-0892 - Updated Banking Details	

Q19 – Email Direction

Objective: *Determine if the email was sent externally or within the organization.*

```
EmailEvents | where SenderDisplayName contains "Smith" | where
SenderFromAddress contains "m.smith@lognpacific.org" | where
SenderIPv4 == "205.147.16.190" | project TimeGenerated,
SenderDisplayName, SenderFromAddress, DeliveryAction,
DeliveryLocation, RecipientEmailAddress, RecipientDomain, Subject,
EmailDirection
```

Thought Process: *Query "EmailEvents" table and search for "EmailDirection".*

Answer: Intra-org

2/25/2026, 10:06:39.000 PM	Mark Smith	m.smith@lognpacific
TimeGenerated [UTC]	2026-02-25T22:06:39Z	
SenderDisplayName	Mark Smith	
SenderFromAddress	m.smith@lognpacific.org	
DeliveryAction	Delivered	
DeliveryLocation	Inbox/folder	
RecipientEmailAddress	j.reynolds@lognpacific.org	
RecipientDomain	lognpacific.org	
Subject	RE: Invoice #INV-2026-0892 - Updated Banking Details	
EmailDirection	Intra-org	

Q20 – BEC Sender IP

Objective: *Check to see if the "SenderIPv4" correlates with the attacker's sign-in IP.*

```
EmailEvents | where SenderDisplayName contains "Smith" | where
SenderFromAddress contains "m.smith@lognpacific.org" | where
SenderIPv4 == "205.147.16.190" | project TimeGenerated,
SenderDisplayName, SenderFromAddress, DeliveryAction,
DeliveryLocation, RecipientEmailAddress, RecipientDomain, Subject,
EmailDirection, SenderIPv4
```

Thought Process: *Search "EmailEvents" table and see if the attacker's "SenderIPv4" and the sign-in IP matches*

Answer: 205.147.16.190

2/25/2026, 10:06:39.000 PM	Mark Smith	m.smith@lognpaci
TimeGenerated [UTC]	2026-02-25T22:06:39Z	
SenderDisplayName	Mark Smith	
SenderFromAddress	m.smith@lognpacific.org	
DeliveryAction	Delivered	
DeliveryLocation	Inbox/folder	
RecipientEmailAddress	j.reynolds@lognpacific.org	
RecipientDomain	lognpacific.org	
Subject	RE: Invoice #INV-2026-0892 - Updated Banking Details	
EmailDirection	Intra-org	
SenderIPv4	205.147.16.190	

Q21 – Cloud App Accessed

Objective: *Check to see if the attacker accessed anything other than emails.*

```
CloudAppEvents | where IPAddress == "205.147.16.190" | where
ActionType contains "FileAccessed" |project TimeGenerated, ActionType,
Application, IPAddress, ObjectName, RawEventData | sort by
TimeGenerated asc
```

Thought Process: *Query in the "CloudAppEvents" table to see if any other files were accessed.*

Answer: Microsoft OneDrive for Business

2/25/2026, 10:07:16.000 PM	FileAccessed	
TimeGenerated [UTC]	2026-02-25T22:07:16Z	
ActionType	FileAccessed	
Application	Microsoft OneDrive for Business	
IPAddress	205.147.16.190	
ObjectName	https://joshmadakorgmail-my.sharepoint.co	
RawEventData	{"CreationTime":"2026-02-25T22:07:16.0000	

Q22 – SharePoint App Accessed

Objective: *Search what other applications the attacker may have accessed.*

```
SigninLogs
| where IPAddress == "205.147.16.190"
| where ResultType == 0
| summarize count() by AppDisplayName
| sort by count_ desc
```

Thought Process: *Use the "SigninLogs" table to query for other apps that may have been accessed.*

Answer: SharePoint Online

☑	One Outlook Web
☐	Office 365 SharePoint Online
☐	SharePoint Online Web Client Extensibility
☐	OfficeHome

Q23 – Session Correlation

Objective: *Find the "Session ID" in the "CloudAppEvents" & "SigninLogs" table to see if it correlates.*

```
CloudAppEvents | where IPAddress == "205.147.16.190" | project
TimeGenerated, ActionType, Application, IPAddress, ObjectName,
RawEventData | sort by TimeGenerated asc
```

```
SigninLogs
| where IPAddress == "205.147.16.190"
| where ResultType == 0
| project TimeGenerated, SessionId, AppDisplayName
```

Thought Process: *Checked both tables and the "Session ID" is the same from both tables.*

Answer: 00225cfa-a0ff-fb46-a079-5d152fcdf72a

AppAccessContext	{"AADSessionId":"00225cfa-a0ff-fb46-a079-5d152
AADSessionId	00225cfa-a0ff-fb46-a079-5d152fcdf72a
IssuedAtTime	2026-02-25T21:51:11.0000000Z
UniqueTokenId	t2zThhpu_0ql-2DX-OoPAA

2/25/2026, 10:09:56.152 PM	00225cfa-a0ff-fb46-a079-5d15...	SharePoint Online Web Client Extensibility
TimeGenerated [UTC]	2026-02-25T22:09:56.152266Z	
SessionId	00225cfa-a0ff-fb46-a079-5d152fcdf72a	
AppDisplayName	SharePoint Online Web Client Extensibility	

Q24 – Conditional Access Status

Objective: *Check to see what the "ConditionalAccessStatus" was during the attacker's successful sign-in.*

```
SigninLogs | where IPAddress == "205.147.16.190" | project
TimeGenerated, ResultSignature, ConditionalAccessStatus, IPAddress |
sort by TimeGenerated asc
```

Thought Process: *Search "SigninLogs" table for "ConditionalAccessStatus"*

Answer: notApplied

2/25/2026, 9:59:52.798 PM	SUCCESS
TimeGenerated [UTC]	2026-02-25T21:59:52.7988431Z
ResultSignature	SUCCESS
ConditionalAccessStatus	notApplied
IPAddress	205.147.16.190

Q25 – MFA Fatigue MITRE ID

Objective: *Figure out the MITRE ID for MFA Fatigue.*

Thought Process: *Use the MITRE ATT&CK mapping table to find ID.*

Answer: T1621

Q26 – Email Rules MITRE ID

Objective: *Figure out the MITRE ID and sub category for Email Rules*

Thought Process: *Use the MITRE ATT&CK mapping table to find ID.*

Answer: T1564.008

Q27 – Credential Source

Objective: *Figure out what type of malware that was used to harvest credentials.*

Thought Process: *Google the characteristics of the malware to come up with the answer.*

Answer: Infostealer

Q28 – Immediate Containment

Objective: *Figure out how to immediately contain this attack.*

Thought Process: *Ask ChatGPT what would be the best immediate action to take to stop the attack and take note of it.*

Answer: Revoke Sessions

Q29 – Threat Actor Attribution

Objective: *Research which financially motivated threat group uses MFA fatigue and BEC against enterprise targets.*

Thought Process: *Ask ChatGPT what group with a Two-Word name has the characteristics of using MFA Fatigue and BEC against enterprise targets.*

Answer: Scattered Spider

FINAL FINDINGS

Full identity-based compromise using MFA fatigue, inbox rule persistence, and BEC.

(End of Report)